



Venus Position Swapper

Security Review

Cantina Managed review by:
Optimum, Lead Security Researcher
Red-Swan, Security Researcher

February 4, 2026

Contents

1	Introduction	2
1.1	About Cantina	2
1.2	Disclaimer	2
1.3	Risk assessment	2
1.3.1	Severity Classification	2
2	Security Review Summary	3
2.1	Scope	3
3	Findings	4
3.1	Low Risk	4
3.1.1	From and To Markets Should Not Be The Same	4
3.2	Informational	4
3.2.1	Code Clarity	4
3.2.2	Missing flash-loan <code>initiator</code> check	4
3.2.3	Awareness of <code>SWAP_HELPER</code> Address Integrity	5
3.2.4	Code quality improvements	5

1 Introduction

1.1 About Cantina

Cantina is a security services marketplace that connects top security researchers and solutions with clients. Learn more at cantina.xyz

1.2 Disclaimer

Cantina Managed provides a detailed evaluation of the security posture of the code at a particular moment based on the information available at the time of the review. While Cantina Managed endeavors to identify and disclose all potential security issues, it cannot guarantee that every vulnerability will be detected or that the code will be entirely secure against all possible attacks. The assessment is conducted based on the specific commit and version of the code provided. Any subsequent modifications to the code may introduce new vulnerabilities that were absent during the initial review. Therefore, any changes made to the code require a new security review to ensure that the code remains secure. Please be advised that the Cantina Managed security review is not a replacement for continuous security measures such as penetration testing, vulnerability scanning, and regular code reviews.

1.3 Risk assessment

Severity level	Impact: High	Impact: Medium	Impact: Low
Likelihood: high	Critical	High	Medium
Likelihood: medium	High	Medium	Low
Likelihood: low	Medium	Low	Low

1.3.1 Severity Classification

The severity of security issues found during the security review is categorized based on the above table. Critical findings have a high likelihood of being exploited and must be addressed immediately. High findings are almost certain to occur, easy to perform, or not easy but highly incentivized thus must be fixed as soon as possible.

Medium findings are conditionally possible or incentivized but are still relatively likely to occur and should be addressed. Low findings are a rare combination of circumstances to exploit, or offer little to no incentive to exploit but are recommended to be addressed.

Lastly, some findings might represent objective improvements that should be addressed but do not impact the project's overall security (Gas and Informational findings).

2 Security Review Summary

Venus Protocol is a leading lending and borrowing platform on the BNB Chain that prioritizes enhanced risk management, decentralization, and user experience.

From Jan 20th to Jan 23rd the Cantina team conducted a review of [venus-periphery](#) on commit hash [bd3458d9](#). The team identified a total of **5** issues:

Issues Found

Severity	Count	Fixed	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	0	0	0
Low Risk	1	1	0
Gas Optimizations	0	0	0
Informational	4	2	2
Total	5	3	2

2.1 Scope

The security review had the following components in scope for [venus-periphery](#) on commit hash [bd3458d9](#):

```
contracts/PositionSwapper
├── IPositionSwapper.sol
└── PositionSwapper.sol
```

3 Findings

3.1 Low Risk

3.1.1 From and To Markets Should Not Be The Same

Severity: Low Risk

Context: *(No context files were provided by the reviewer)*

Description: In both `swapCollateral` and `swapDebt` functions, the `marketFrom` and `marketTo` parameters are not checked to be distinct. This would allow a user to perform the non-sensical operation of removing their debt or collateral only to pay for it to be swapped for itself and then put back where it was. Such an action goes against the intent of the contract.

Recommendation: To reduce the attack surface of the contract and protect users from performing actions they do not need, consider requiring that those two parameters are distinct.

Venus Protocol: Fixed in [PR 46](#).

Cantina Managed: Fix verified.

3.2 Informational

3.2.1 Code Clarity

Severity: Informational

Context: *(No context files were provided by the reviewer)*

Description: There are several points within the `PositionSwapper` contract where the code could be made more accurate.

- The comment on line 441 has the word "whome" which is a misspelling of "whom".
- The `calculateFlashLoanAmount` function is internal and therefore should follow the style of the other internal functions and be named with a leading underscore (i.e. `_calculateFlashLoanAmount`).
- Both `_swapCollateralNativeToWrapped` and `_swapDebtNativeToWrapped` call `executeFlashLoan` with a `param` argument of "0x" (or `0x3078`). This is ignored by the relevant `_execute*` functions but signify their irrelevance better by using the empty string "" instead.

Recommendation: Consider making the changes suggested above.

Venus Protocol: Fixed in [340b49f](#).

Cantina Managed: Fix verified.

3.2.2 Missing flash-loan initiator check

Severity: Informational

Context: [PositionSwapper.sol#L453](#)

Description: The `PositionSwapper` contract implements `executeOperation` as the callback for Venus Protocol flash loans. While the function verifies that the `msg.sender` is the `COMPTRROLLER`, it fails to validate the `initiator` address.

In a standard flash loan flow, the `initiator` is the account that triggered the loan. By omitting this check, the contract technically allows the callback logic to be triggered by an external entity (an attacker) who initiates a flash loan through the `Comptroller` and targets this contract as the receiver.

While the use of `transient` storage currently restricts the contract to operations it started itself, this lack of validation creates a "fragile" security state. If future upgrades or integration with other periphery contracts allow the `operationType` to be influenced externally, an attacker could hijack the callback to execute unauthorized swaps or debt repayments on behalf of users who have granted the contract delegate permissions.

Recommendation: Strictly validate that the `initiator` of the flash loan is `address(this)`. This ensures that the `executeOperation` logic can only proceed if the contract itself triggered the workflow, providing a robust second layer of defense alongside the `transient` state checks.

Venus Protocol: Fixed in commit [9a3e27c](#).

Cantina Managed: Fix verified.

3.2.3 Awareness of `SWAP_HELPER` Address Integrity

Severity: Informational

Context: [PositionSwapper.sol#L725](#)

Description/Recommendation: The `PositionSwapper` uses an immutable `SWAP_HELPER` to execute swaps. While this address is protocol-set and verified via governance, it is worth noting the theoretical risk if the helper were ever misconfigured to match a `vToken` contract address.

Because the contract passes user-provided `swapData` to the helper, a `vToken` acting as the `SWAP_HELPER` could potentially be manipulated to execute `transferFrom()` calls.

Venus Protocol: Acknowledged. The `SWAP_HELPER` address will be configured only to the correct, audited swap helper contract.

Cantina Managed: Acknowledged.

3.2.4 Code quality improvements

Severity: Informational

Context: *(No context files were provided by the reviewer)*

Description:

1. Redundant State Variable Usage: Internal functions `_swapCollateralNativeToWrapped` and `_swapDebtNativeToWrapped` rely on the immutable `WRAPPED_NATIVE_MARKET` instead of the provided `marketTo` parameter.
2. Non-Standard Function Layout: The `executeOperation` callback is located among internal helpers rather than with other external functions. Following the Solidity Style Guide (grouping functions by visibility) improves scannability, as this is a primary protocol entry point.

Recommendation:

1. Refactor Internal Logic: Update native swap helpers to use the `marketTo` parameter for all destination market logic.
2. Relocate `executeOperation`: Move the callback to the external function section to align with industry standards and improve auditability.

Venus Protocol: Acknowledged.

- This is intentional to improve code readability and clarity. The native-to-wrapped swap flow is conceptually different from the generic swap logic, and directly using the immutable `WRAPPED_NATIVE_MARKET` makes it explicit which market is involved in the flash loan and repayment flow. This improves code comprehension and reduces the risk of incorrect market usage.
- The current placement of `executeOperation()` is more readable from a logical flow perspective. Although it's externally visible, it's only a protocol callback and not directly user-callable, so grouping it with the related internal helper logic makes the execution path easier to follow.

Cantina Managed: Acknowledged.